

PRUEBA TÉCNICA · CIBERSEGURIDAD

Hardening AWS y Cumplimiento

CIS AWS 1.4 · ISO/IEC 27001:2022 · Ley 1581

PREPARADO POR	Lady Marcela Romero Rivero
ROL	Líder de Ciberseguridad
CLIENTE	Simon Movilidad
ESCENARIO	FleetSec S.A.S. — Telemetría de flotas
FECHA	25 de agosto de 2026
VERSIÓN	1.0

CONFIDENCIAL — Exclusivo para Simon Movilidad

Tabla de contenido

Cada fila enlaza con evidencia concreta en este repositorio. Estado: **PASS** (implementado), **FAIL** (brecha), **N/A** (fuera del alcance de este entregable).

#	Control (CIS AWS 1.4)	ISO 27001:2022	Ley 1581	Implementación	Evidencia
1	1.4 Sin claves de acceso root / 1.5 MFA en root	A.5.16, A.8.5	Art. 4 (seguridad)	Regla de Config <code>root-account-mfa-enabled</code> ; no se crean claves de root	<code>terraform/.../monitoring.tf</code> (config_rules), <code>iam.tf</code>
2	1.8 Política de contraseñas ≥14, reutilización 24, 90d	A.5.17	Art. 4	<code>aws_iam_account_password_policy</code> (14/90/24)	<code>iam.tf</code>
3	1.16 Sin <code>AdministratorAccess</code> / comodines en producción	A.5.15, A.8.2	Art. 4 (acceso restringido)	Roles ECS de mínimo privilegio; S3/KMS/Secrets acotados	<code>iam.tf</code>
4	2.1.1 SSE de S3 + 2.1.5 Block Public Access	A.8.24	Art. 4	BPA de cuenta + BPA por bucket + SSE-KMS CMK	<code>s3.tf</code>
5	2.1.2 S3 deniega transporte inseguro (TLS)	A.8.24	Art. 4	Bucket policy que deniega <code>aws:SecureTransport=false</code>	<code>s3.tf</code>
6	3.1 CloudTrail habilitado en todas las regiones	A.8.15	Art. 4	Trail multirregión + eventos de gestión + eventos de datos de S3	<code>monitoring.tf</code>
7	3.2 Validación de archivos de log de CloudTrail	A.8.15	Art. 4	<code>enable_log_file_validation = true</code>	<code>monitoring.tf</code>
8	3.4 CloudTrail → CloudWatch Logs	A.8.15, A.8.16	Art. 4	<code>cloud_watch_logs_group_arn</code> conectado	<code>monitoring.tf</code>
9	3.7 Rotación de CMK de KMS habilitada	A.8.24	Art. 4	<code>enable_key_rotation = true</code> (claves RDS/S3/ECS)	<code>kms.tf</code>
10	3.8 Logging a nivel de bucket S3	A.8.15	Art. 4	<code>aws_s3_bucket_logging</code> en telemetría + logs	<code>s3.tf</code>
11	4.1 Filtro de métrica: API no autorizada / root	A.8.16	Art. 4	Filtros de métrica + alarmas → SNS (root, IAM, SG, KMS, trail)	<code>monitoring.tf</code>
12	4.3 Alarma ante uso de root	A.8.16	Art. 4	Filtro de métrica <code>root_login</code> + alarma	<code>monitoring.tf</code>
13	5.2 Sin ingreso de SG 0.0.0.0/0 al 22	A.8.20, A.8.22	Art. 4	Los SG restringen los puertos de administración; Checkov CKV_AWS_24 + CKV2_FLEETSEC_1	<code>securitygroups</code> <code>checkov/</code>
14	5.3 Sin ingreso de SG 0.0.0.0/0 al 3389	A.8.20	Art. 4	Igual; Checkov CKV_AWS_25 aprueba	<code>securitygroups</code>
15	5.4 El SG por defecto restringe todo el tráfico	A.8.20	Art. 4	<code>aws_default_security_group</code> (sin reglas)	<code>vpc.tf</code>
16	RDS: cifrado + Multi-AZ + sin acceso público	A.8.24, A.8.14	Art. 4, Art. 17	CMK, Multi-AZ, <code>publicly_accessible=false</code> , TLS forzado	<code>rds.tf</code>

#	Control (CIS AWS 1.4)	ISO 27001:2022	Ley 1581	Implementación	Evidencia
17	GuardDuty habilitado (detección de amenazas)	A.5.7 (inteligencia de amenazas), A.8.16	Art. 4	Detector en todas las regiones + S3 + malware + Threat Intel Set	monitoring.tf , detection/threat-intel/
18	Security Hub FSBP + CIS 1.4	A.5.36, A.8.16	Art. 4	Suscripciones a estándares FSBP + CIS 1.4.0	monitoring.tf
19	Grabador de AWS Config + reglas gestionadas	A.8.9 (gestión de configuración)	Art. 4	Grabador + 7 reglas gestionadas	monitoring.tf
20	WAFv2 en ALB (SQLi, bad inputs, rate, geo)	A.8.20, A.8.23	Art. 4	Reglas gestionadas de WAF en BLOCK + rate limit + geo CO/PE/US	waf.tf
21	Secretos en Secrets Manager (rotación 30d)	A.8.24, A.5.17	Art. 4	aws_secretsmanager_secret + rotación	rds.tf , remediación V-10
22	Logs inmutables (Object Lock COMPLIANCE)	A.8.15, A.5.28	Art. 4	Object Lock COMPLIANCE en el bucket de logs/evidencia	s3.tf
23	VPC Flow Logs → S3 + CloudWatch	A.8.16, A.8.20	Art. 4	aws_flow_log para TODO el tráfico	vpc.tf
24	Enmascaramiento de datos / protección de PII	A.8.11 (NUEVO 2022)	Art. 4 (minimización)	Sanitizador de PII en logs (remediación V-08)	app/src/lib/pii
25	Codificación segura (SDLC)	A.8.28 (NUEVO 2022)	—	Reglas personalizadas de Semgrep + puerta SAST + gemelos seguros / secure	semgrep/ , .git workflows/
26	Proceso de respuesta a incidentes	A.5.24-5.28	Art. 4 + SIC 15 días	Playbook de IR + reglas Sigma + ruta de notificación a la SIC	detection/playbooks/
27	Notificación de brecha a la SIC (15 días hábiles)	A.5.24	Art. 17	Ruta de notificación + plantilla + cronología	detection/playbooks/ir-playbook.md §6
28	Replicación de S3 entre regiones	A.8.14	Art. 17	No implementado (riesgo aceptado documentado)	s3.tf checkov:CKV_AWS_144

Cobertura: 27 PASS / 0 FAIL / 1 N/A (aceptado, documentado). ≥ 10 controles mapeados según lo exigido.

Controles ISO 27001:2022 «nuevos en 2022» cubiertos: A.5.7 (inteligencia de amenazas), A.8.9 (gestión de configuración), A.8.11 (enmascaramiento de datos), A.8.16 (monitoreo), A.8.23 (filtrado web/WAF), A.8.28 (codificación segura).